Universidad Andres Bello - 2026

MICROSOFT DETECTION
AND RESPONSE TEAM (DART)

From one identity to full compromise



SPEAKER

Sergio S. Matavos Galan

Meet the speaker



Sergio S. Matavos Galan

Senior Security Researcher
Microsoft DART

Buenos Aires, Argentina


```
Administrator: Windows PowerShell

PS C:\Users\Sergio> Get-Description

  Incident response and security researcher focused on identity,
  cloud and infrastructure compromise.


PS C:\Users\Sergio> Get-Experience

  12+ years at Microsoft

PS C:\Users\Sergio> Get-FocusAreas | ForEach-Object { "[+] $_" }

  [+] DFIR & Incident Response
  [+] Identity Security
  [+] Cloud & Defender XDR


PS C:\Users\Sergio> Get-Team

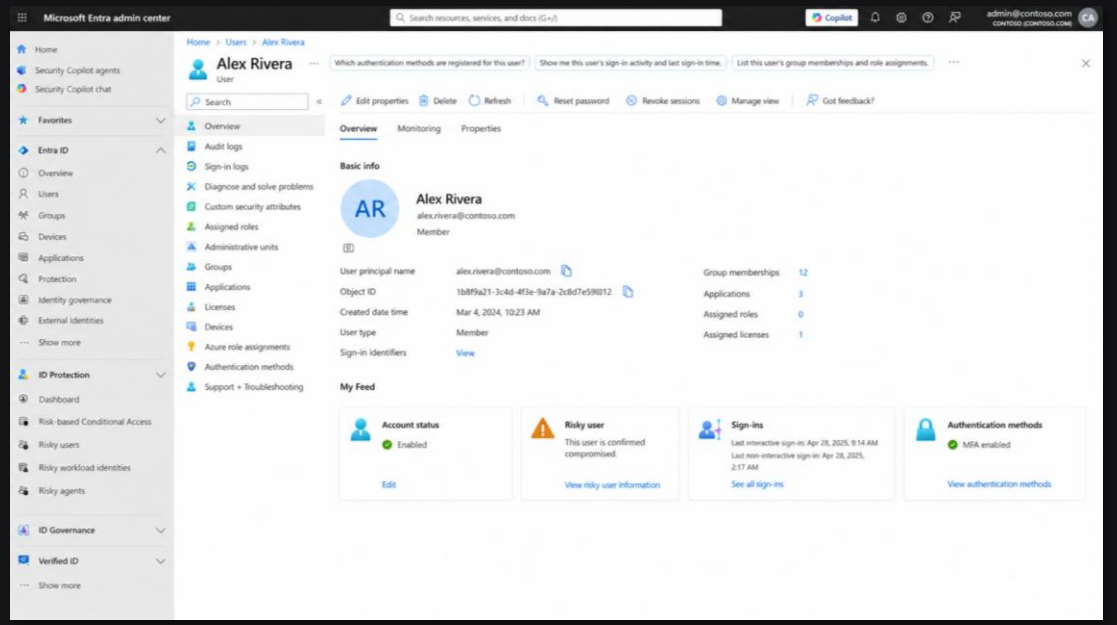
  Microsoft DART

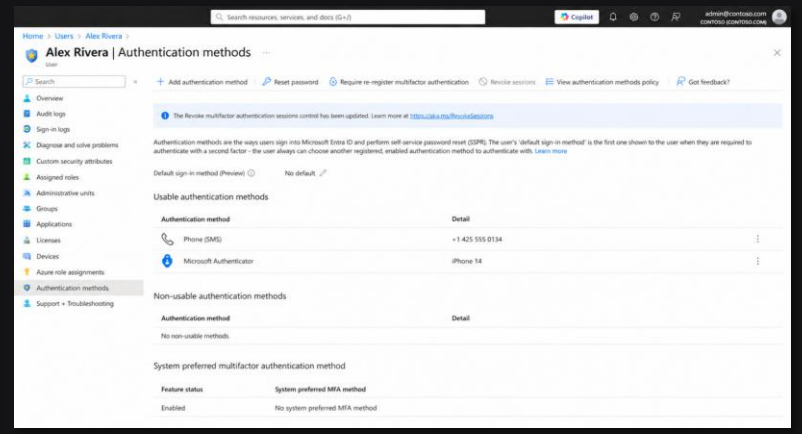
PS C:\Users\Sergio> _
```

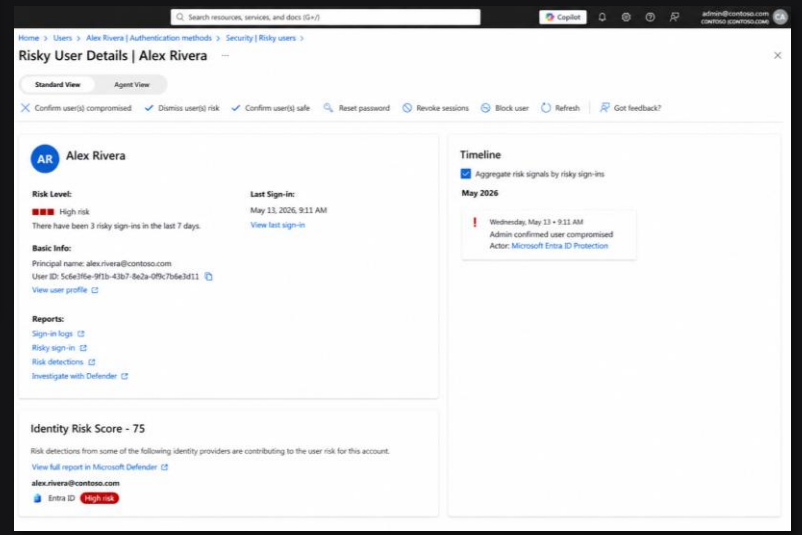
It starts with an identity that does not look critical

Case: Alex Rivera · valid identity, limited apparent privilege

- Standard user
- MFA enabled
- No obvious admin role
- Compromised







The investigation starts after the attacker already has Alex's valid identity.

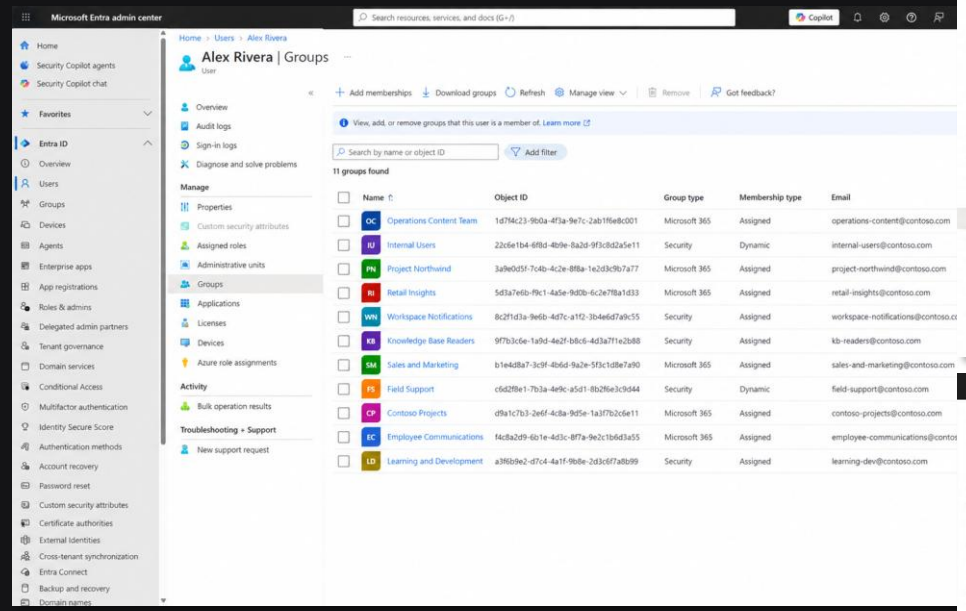
Direct permissions tell only part of the story

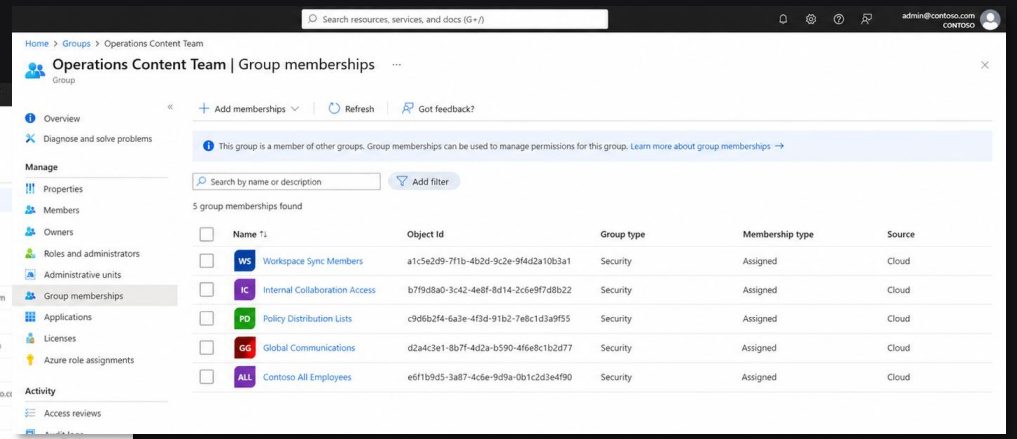
Case: Alex Rivera · direct assignments still look low risk

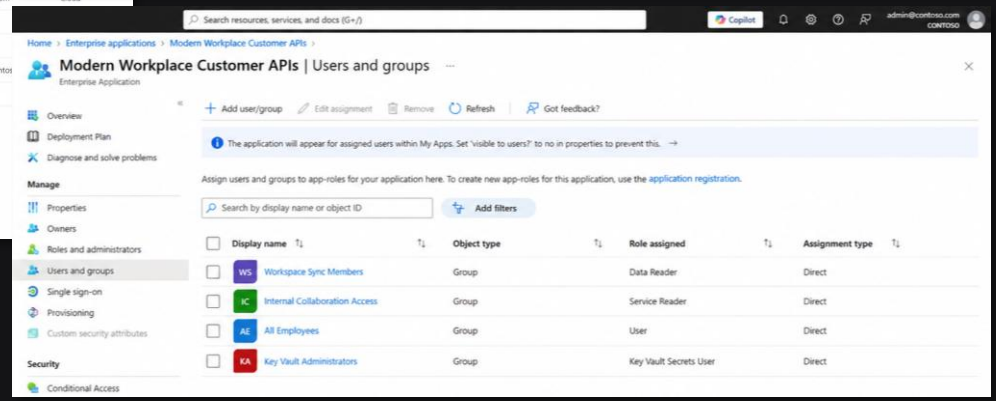
Direct view

User → Few visible roles

Looks low risk when viewed in isolation





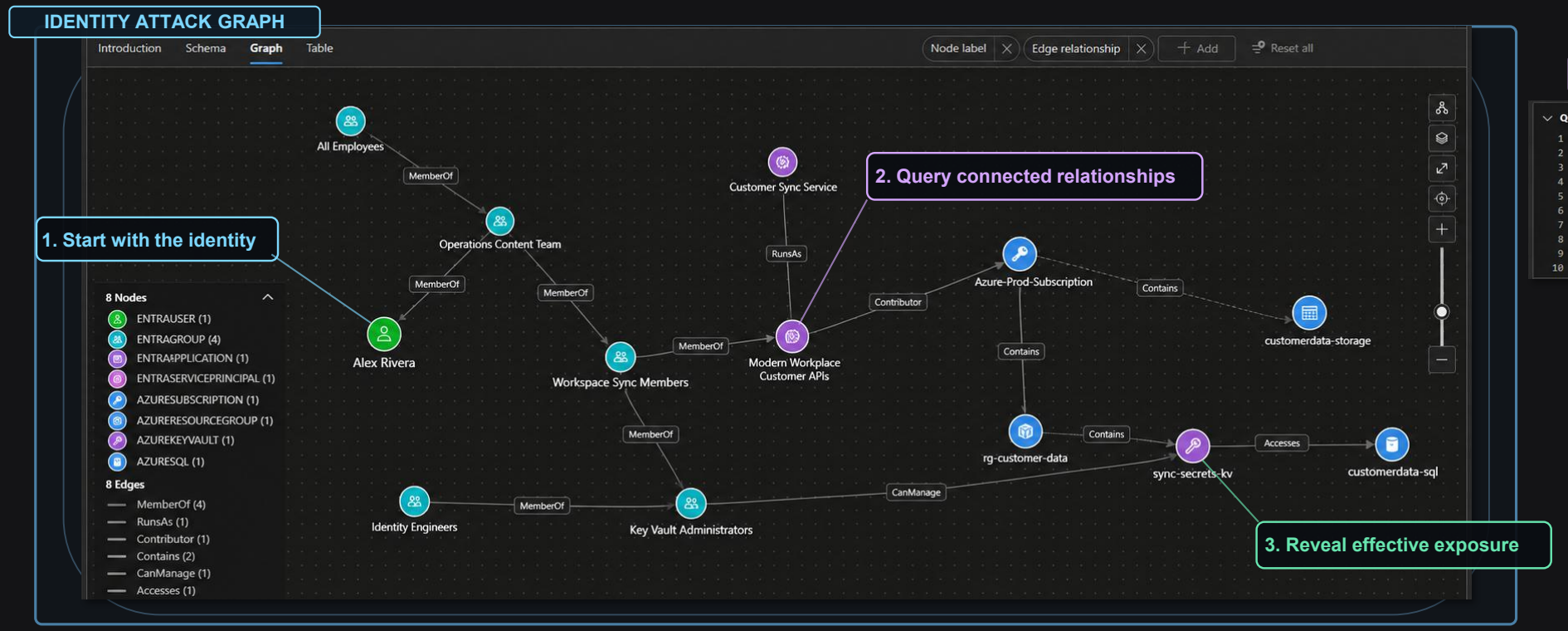


Direct access ≠ Effective access

The attack path we could not see

Identity Attack Graph reveals effective exposure across connected relationships

Case: Alex Rivera · direct assignments looked limited. Identity Attack Graph revealed what those relationships could reach.



GQL Query

```
Query
1  MATCH
2        (u:ENTRAUSER)
3        -[r1 { sys_label: 'MemberOf' }]->
4        (g1:ENTRAGROUP)
5        -[r2 { sys_label: 'MemberOf' }]->
6        (g2:ENTRAGROUP)
7        -[r3 { traversable: 'true' }]->{1,6}
8        (kv:AZUREKEYVAULT)
9  RETURN *
10 LIMIT 100
```

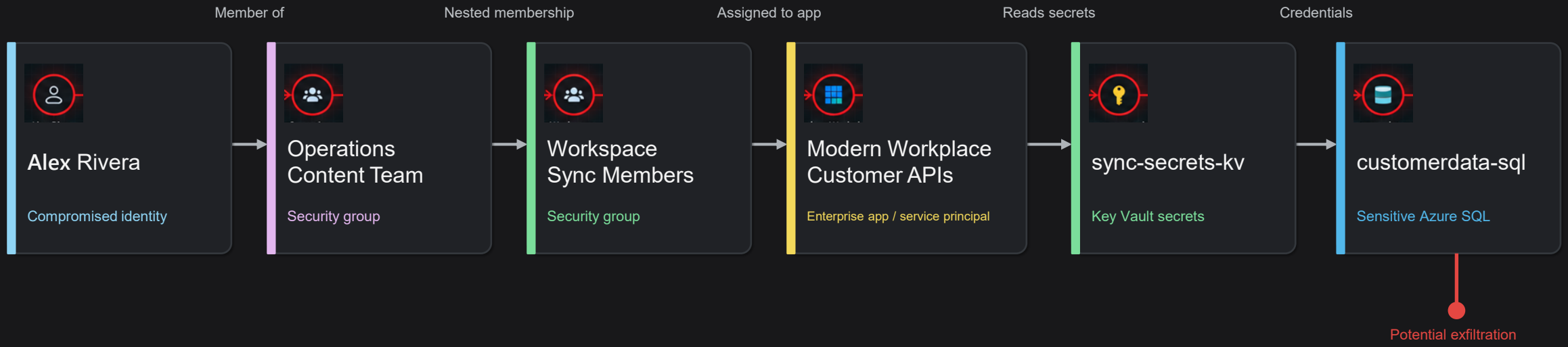
Representative visualization based on validated relationships in the case

Direct access ≠ Effective exposure

Effective exposure emerges when identities, permissions and resource relationships are connected.

One relationship may be harmless. Combined, they are not

Case: Alex Rivera · exposure emerges from the chain



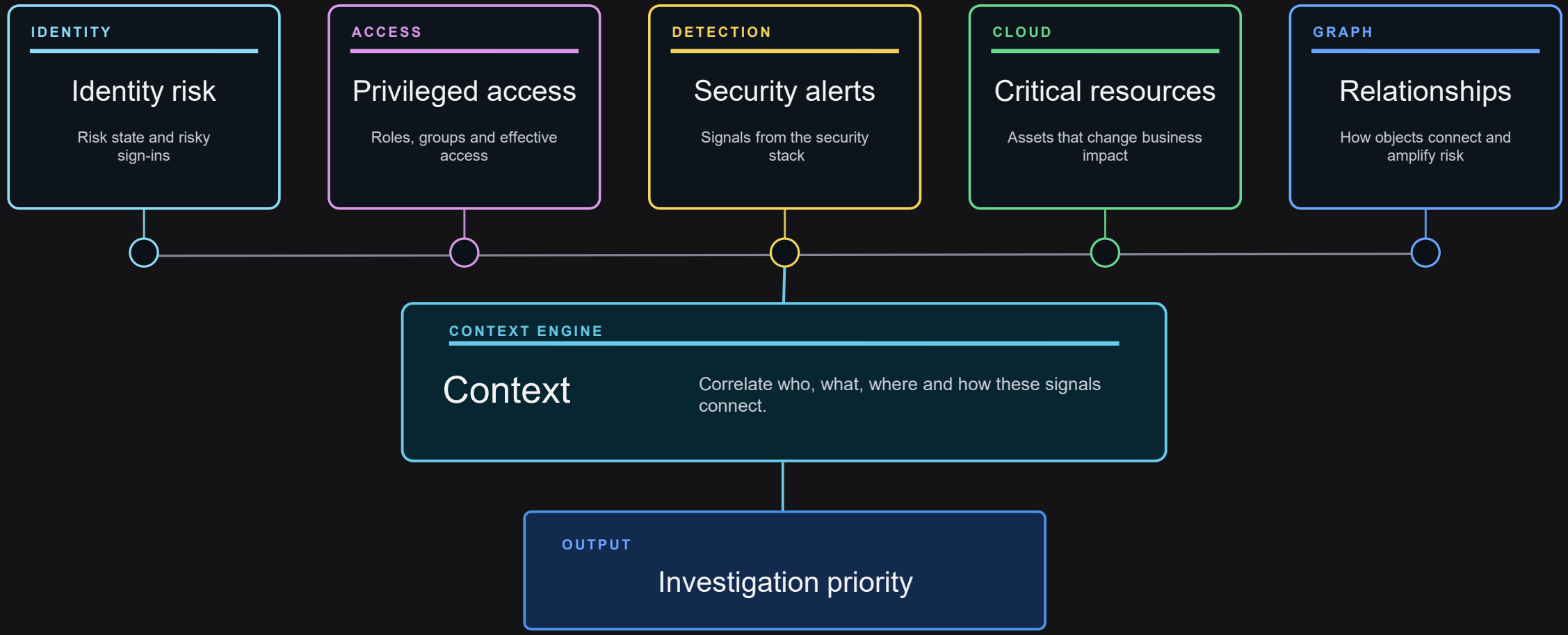
The risk is created by the chain, not by a single permission.

Nothing in isolation looked critical. The exposure appears only when the relationships are connected.

Want to know more: Identity Attack Graph

We have the signals. Now we need context.

Case: Alex Rivera · multiple signals now point to the same identity

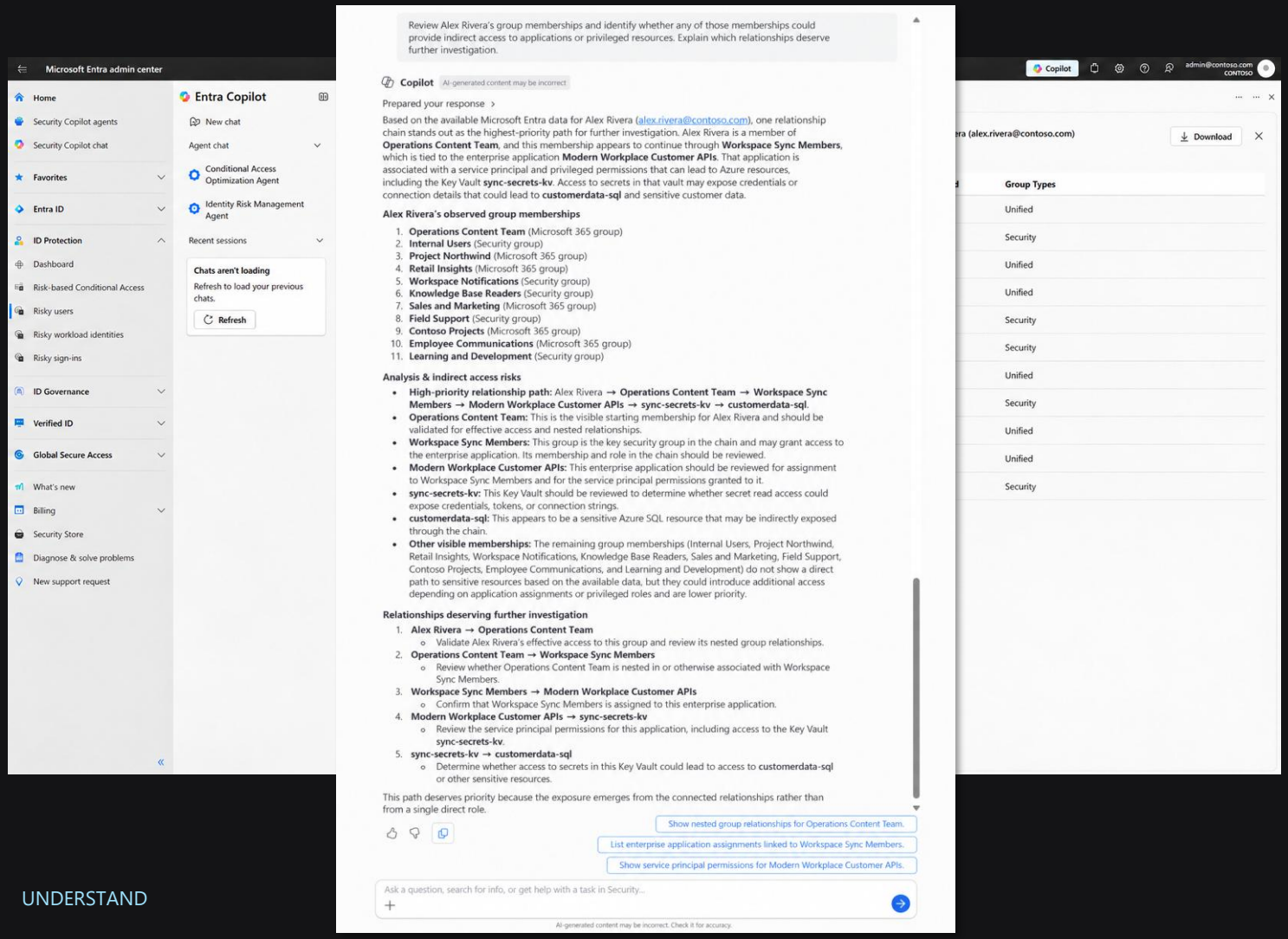


Context turns signals into priorities.

AI can accelerate the investigation. It does not replace it

Entra ID Agent and AI capabilities

Case: Alex Rivera · use AI to prioritize, then validate the evidence



What should we validate?

- Ask the right question
- Evidence behind the answer
- Analyst validation
- Decision ownership

UNDERSTAND

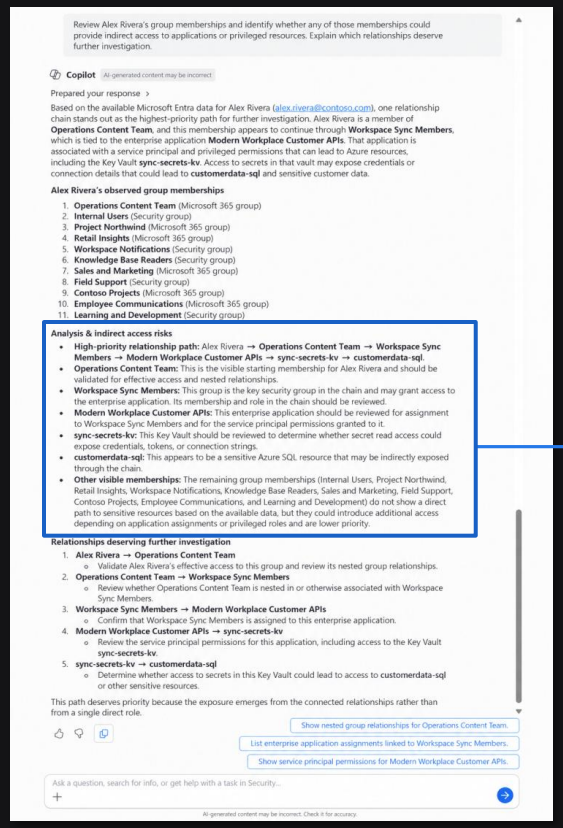
Want to know more: AI for Security in Microsoft Entra

AI prioritized the path. Now we validate it.

From AI-guided investigation to analyst-validated evidence

Case: Alex Rivera · follow the evidence beyond identity

AI PRIORITIZES



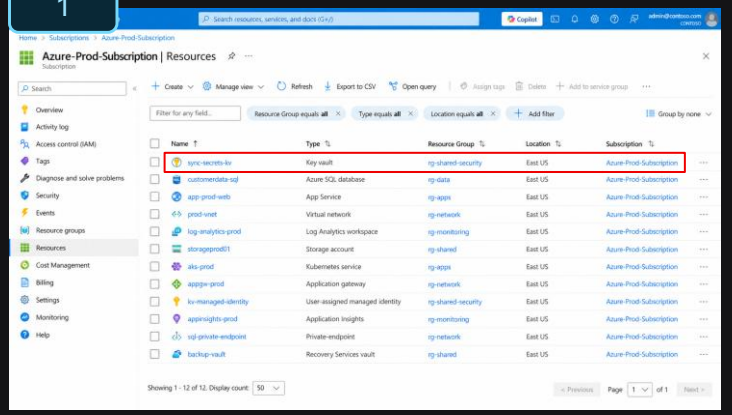
VALIDATE

Follow the evidence

ANALYST VALIDATES

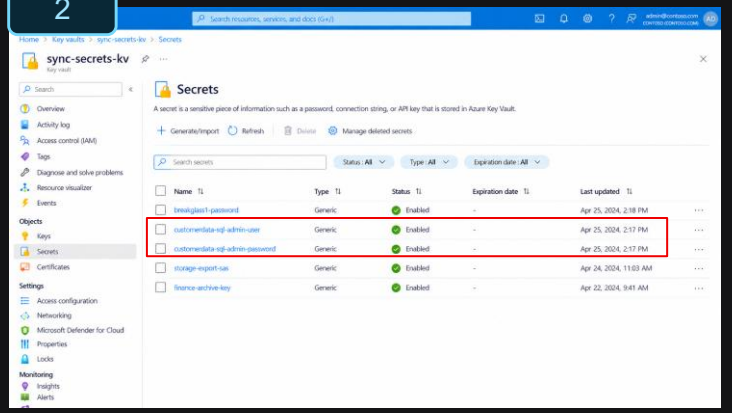
RESOURCE PATH

1



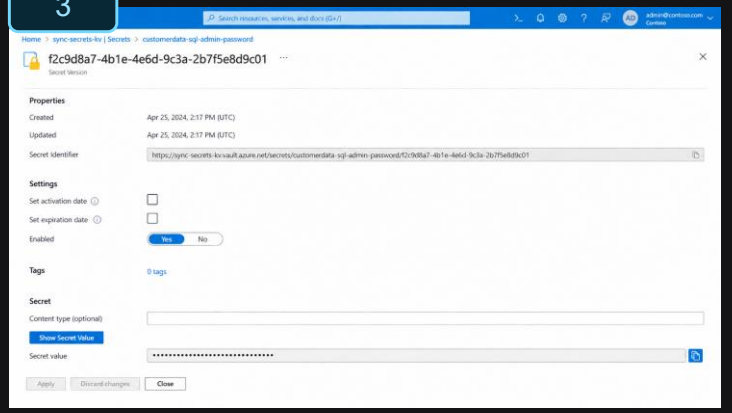
SENSITIVE VAULT

2



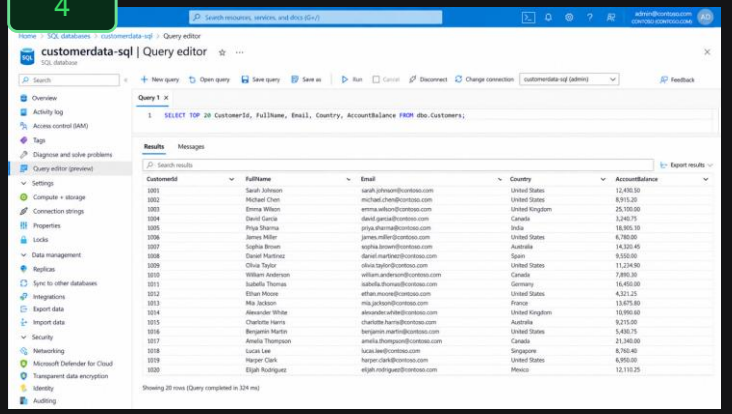
CREDENTIAL

3



DATA EXPOSURE

4

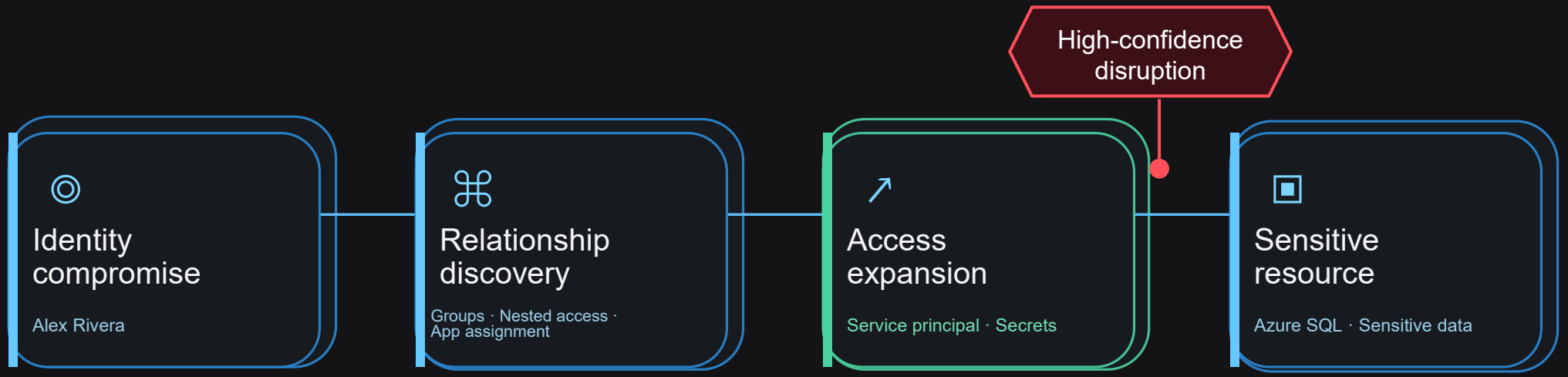


UNDERSTAND

Want to know more: AI for Security in Microsoft Entra

When do we stop investigating and start acting?

Case: Alex Rivera · the investigation now has enough context to consider action



Defender acts when correlated signals establish high confidence that an attack is in progress.

Automatic Attack Disruption is not magic. It is correlation

Automatic Attack Disruption in Microsoft Defender

Case: Alex Rivera · multiple signals converge into one high-confidence incident



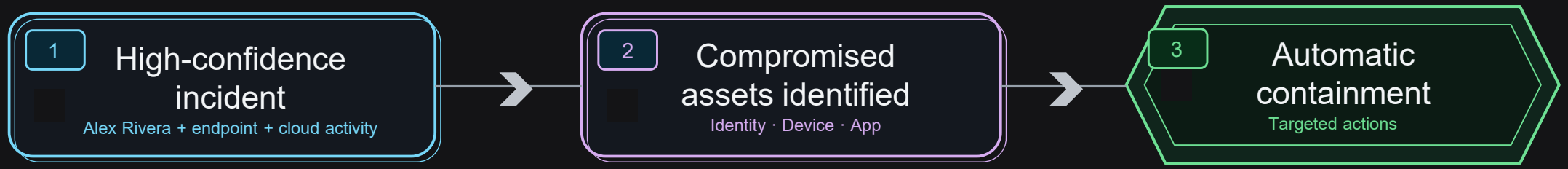
One signal may not justify disruption. Correlated signals can.

Want to know more: Automatic Attack Disruption

What does Attack Disruption actually stop?

Incident-level containment designed to limit attacker movement while responders remediate

Case: Alex Rivera · containment targets attacker-controlled identity and related assets



Containment actions

Revoke sessions	Cuts active attacker sessions
Contain user	Limits use of the compromised identity
Isolate device	Blocks the attacker foothold
Contain app	Restricts compromised application access

What does this stop?

Session reuse	Attacker cannot keep replaying active sessions
Lateral movement	Slows spread across related identities and assets
Continued access	Reduces ongoing use of compromised resources
Progress to sensitive resources	Helps interrupt movement toward key data

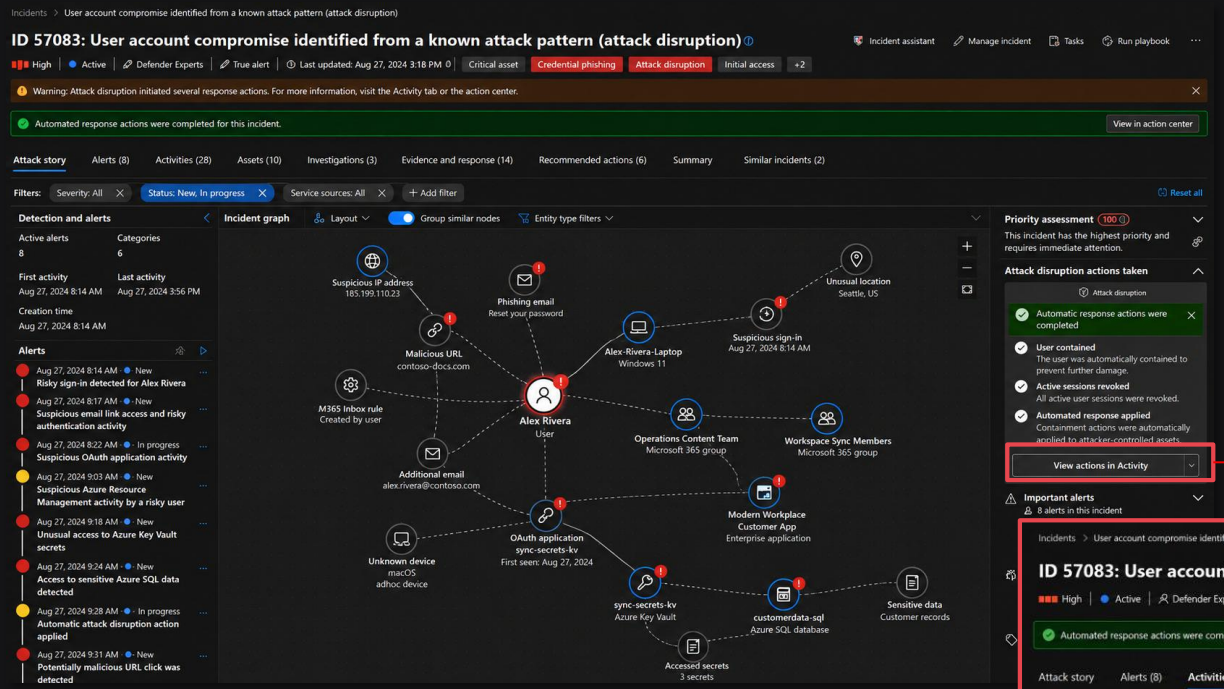
Disruption buys response time. It does not replace remediation.

Want to know more: Automatic Attack Disruption

What does Attack Disruption look like in practice?

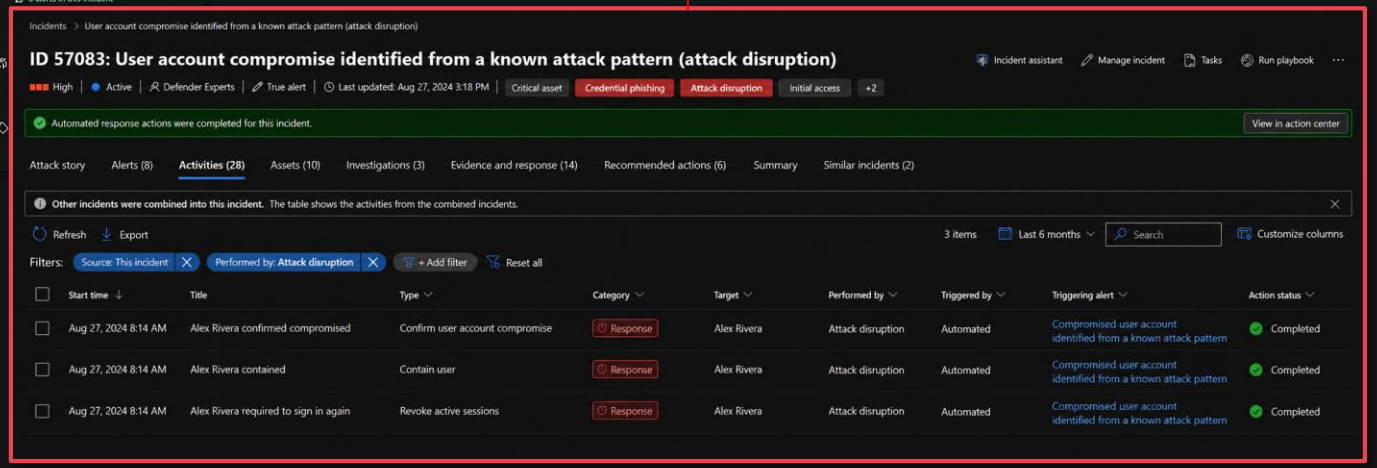
Automatic Attack Disruption in Microsoft Defender

Case: Alex Rivera · correlated evidence triggers and records automatic response



Multiple identity, endpoint, app and cloud signals converge into one high-confidence incident.

The Activity view provides an auditable record of what Attack Disruption actually did.

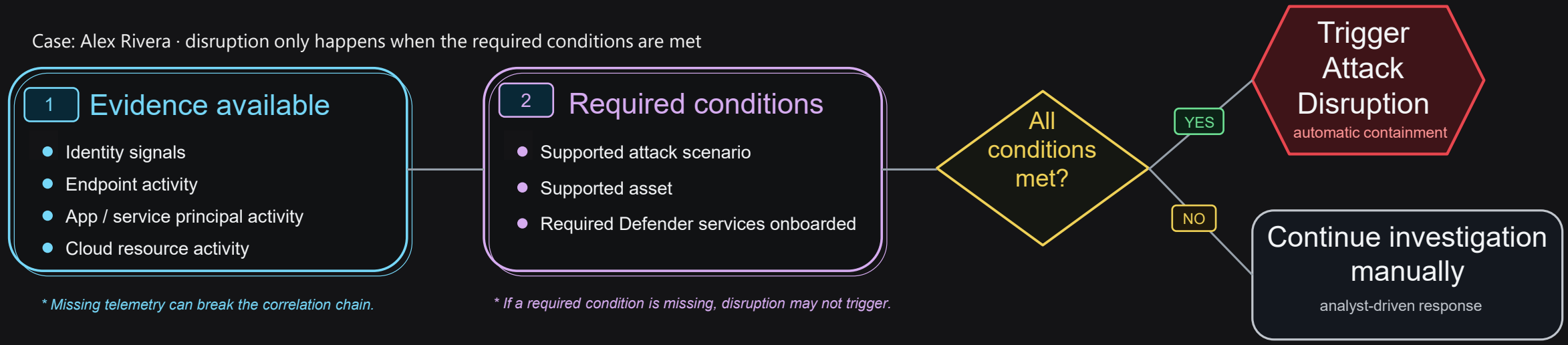


DISRUPT

Want to know more: [Automatic Attack Disruption]

What if Attack Disruption does not trigger?

Case: Alex Rivera · disruption only happens when the required conditions are met



Alex Rivera example

Identity risk + endpoint activity + cloud activity may be present, but if a required condition or supported scenario is missing, Defender may not trigger automatic disruption.

No disruption does not mean no compromise. It means the conditions for automatic containment were not met.

Want to know more: Automatic Attack Disruption

Attack disrupted. Are we recovered?

Case: Alex Rivera · contained does not mean restored

ATTACK DISRUPTED

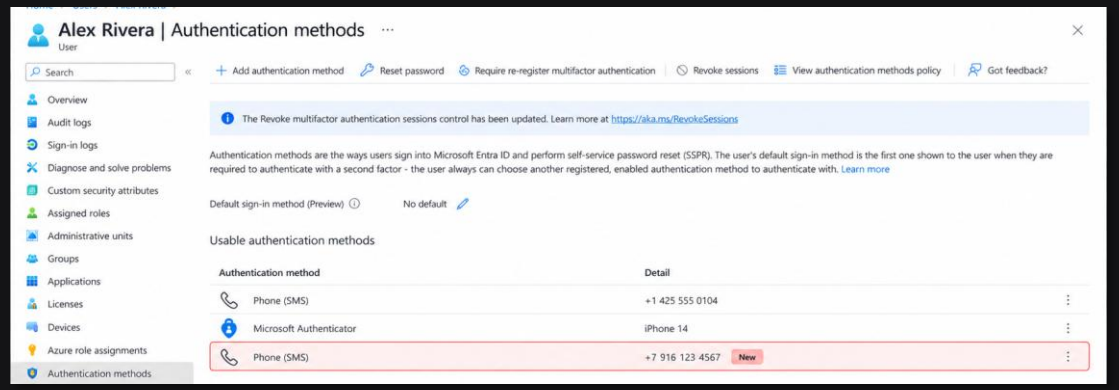
- Sessions revoked
- User contained
- Device isolated

Attacker movement stopped

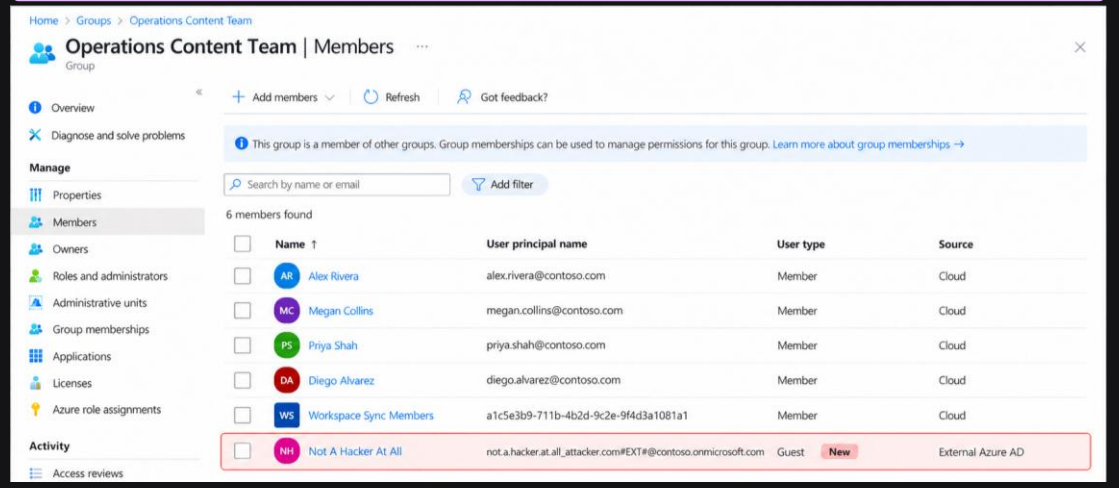
Containment stops the attacker. Recovery restores trusted state.

What may already have changed?

AUTH



GROUP



Want to know more: Attack Disruption results

Restore trust, not just configuration

Microsoft Entra Backup and Recovery

Case: Alex Rivera · recover a known-good identity state

1 Known-good

Expected auth
Expected groups
Expected identity access

2 Compromised

Malicious auth added
Guest introduced
Identity state drift

3 Recovered

Malicious changes removed
Expected access restored
State validated

Restore affected identity objects

Compare

Alex Rivera

- +7 phone added
- Guest in group
- Trust state changed

Restore

Selected for recovery

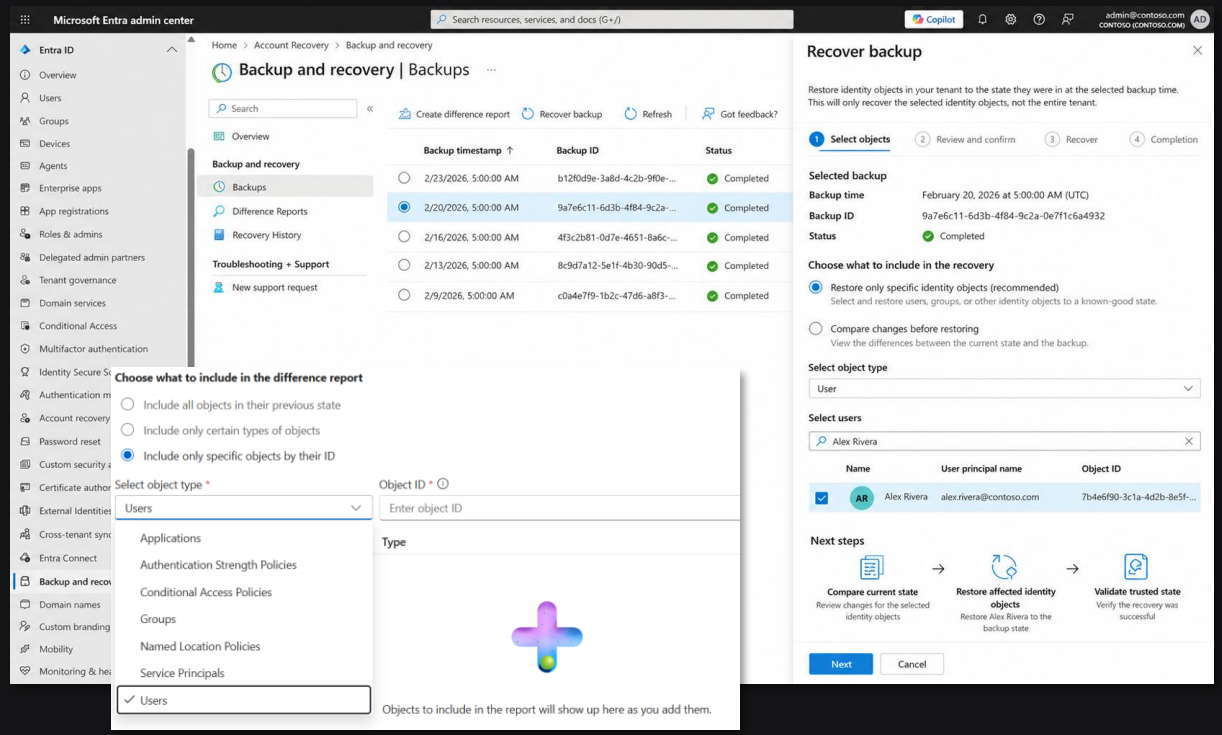
- Remove malicious auth
- Remove guest member
- Restore expected group state

Validate

Post-restore checks

- Expected auth methods only
- Group membership trusted
- Identity state trusted

Targeted object recovery, not a rollback of the entire tenant



RECOVER

Want to know more: Microsoft Entra Backup and Recovery

Authentication is not always enough to establish trust

Microsoft Entra Verified ID

Case: Alex Rivera · verify the person before restoring trust

SIGNAL

Suspicious activity

Risk changes the question from access to trust.

01 Risk detected

VALIDATE

Verify identity

Use an independent proof before remediation.

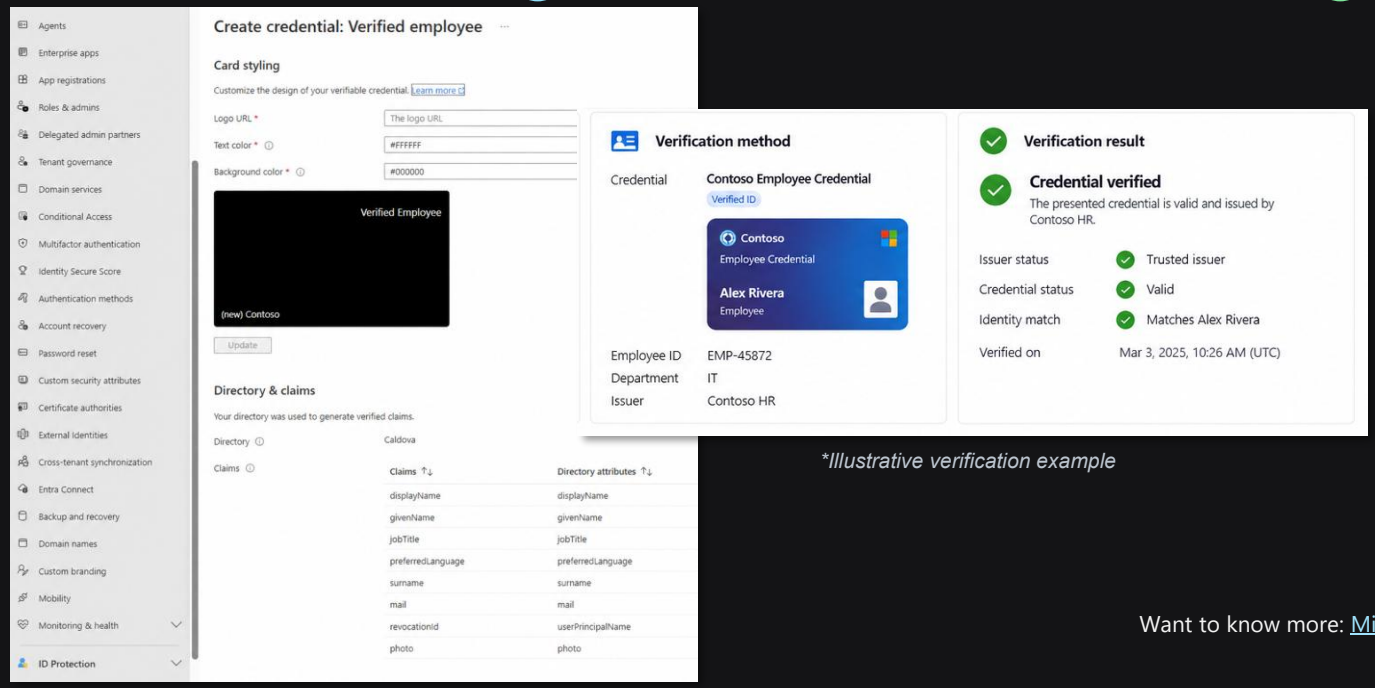
02 Stronger identity proof

DECIDE

Trust decision

Restore access only after confidence is re-established.

03 Trust restored



Illustrative verification example

UNDERSTAND

Want to know more: Microsoft Entra Verified ID

What else could we recover?

Microsoft Entra Backup and Recovery

Case extension: Alex Rivera · restoring a compromised application to a known-good state

1 Known-good

Approved permissions
Expected API access
Trusted application state

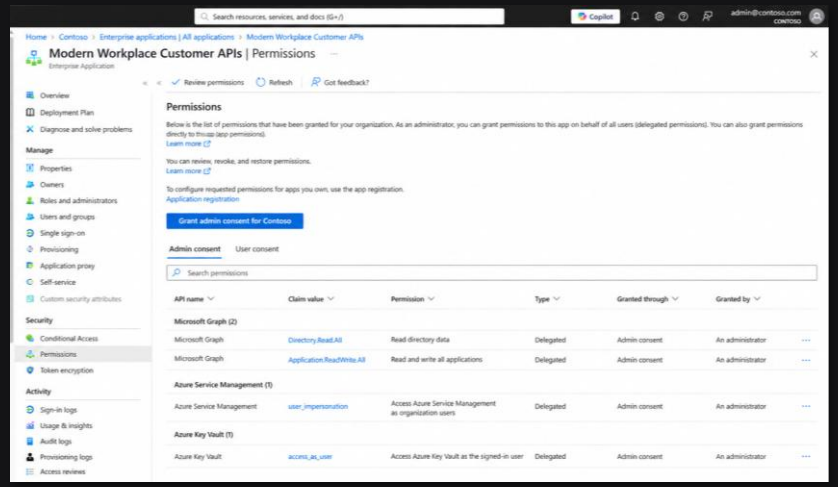
2 Compromised

New permission granted
Storage.Blob.Read.All added
Application state changed

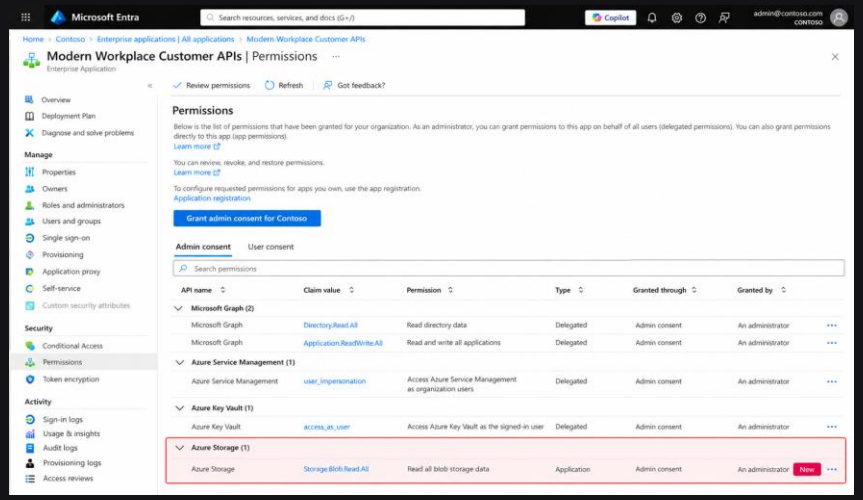
3 Recovered

Unauthorized permission removed
Approved permissions restored
Application state validated

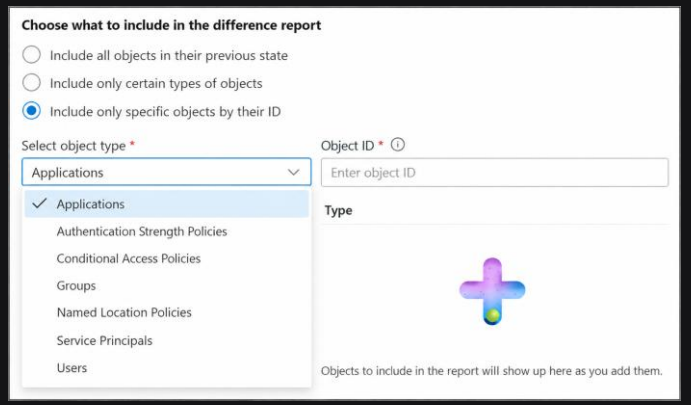
BASELINE



DRIFT DETECTED



SELECT FOR RECOVERY



RECOVER

Want to know more: Microsoft Entra Backup and Recovery

From one identity to the entire incident

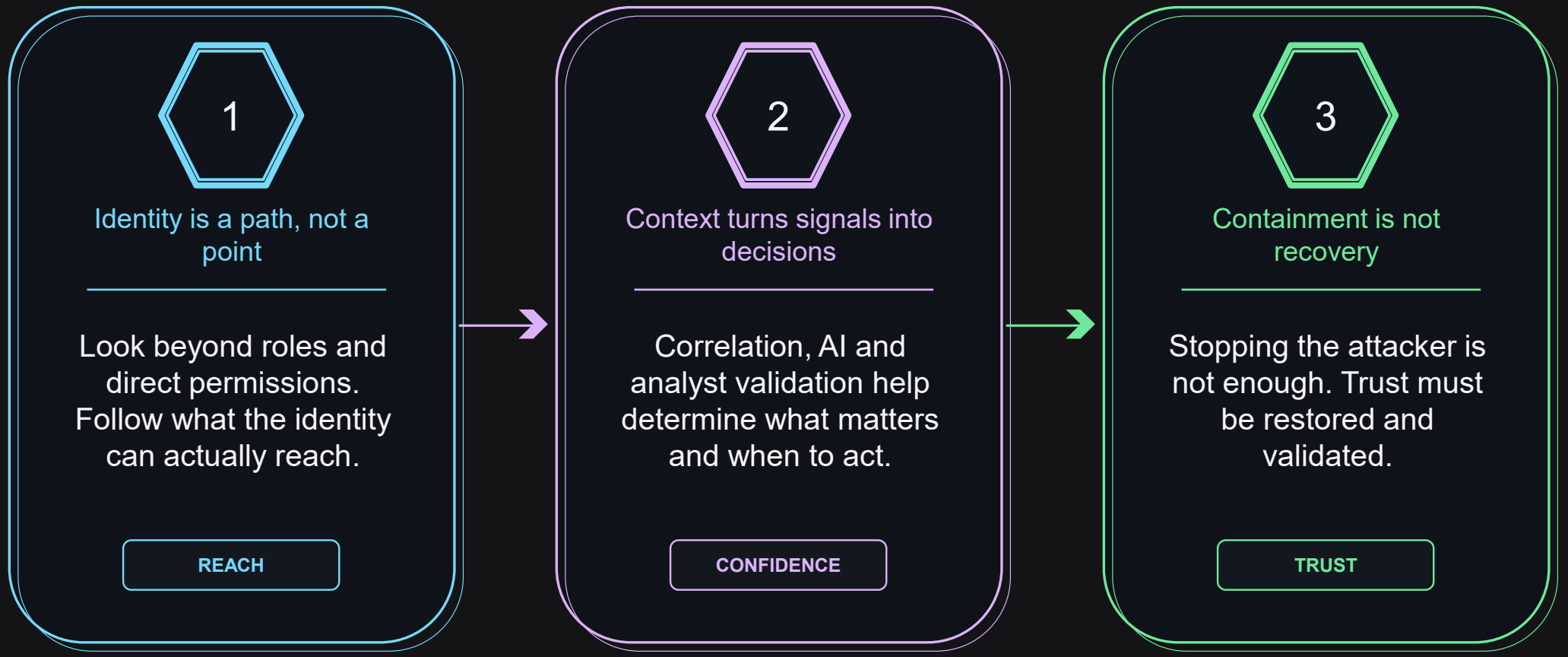
Case: Alex Rivera · one incident from compromise to trusted recovery



One incident. Different decision points. One identity-driven story.

Three things to take away

The story in three decisions



Follow the path. Build the context. Restore the trust.

Questions

Thanks for your time.

PRESENTATION – FEEDBACK - RESOURCES

Sergio S. Matavos Galan

